MAILSHIELD

Email Header Analyzer

Detects spoofing, phishing & authentication anomalies
in raw email headers - 100% local, 100% offline.

Project overview - features - architecture - privacy

github.com/BhonePyaeMin/Mail-Shield

Project Overview

MailShield is a lightweight, local, offline-first cybersecurity tool that analyzes raw email headers and surfaces indicators commonly associated with spoofing, phishing, and authentication anomalies. It's built as a practical demonstration of how much can be learned from headers and message content alone - without ever touching attachments or calling out to an external service.

Every email carries metadata added by mail servers and clients along the way - the sender identity, the Received chain each hop adds, and SPF / DKIM / DMARC authentication results. Careful analysis of that trail can reveal a sender address that doesn't match where replies actually go, failed authentication, lookalike domains crafted to impersonate a trusted brand, and inconsistent routing or timestamp information.

Key Features

- Header + file analysis - paste raw headers or upload a .eml / .txt file, parsed with Python's standard email module.
- SPF / DKIM / DMARC extraction - reads the authentication results already reported in the headers (no live DNS lookups).
- Sender identity checks - cross-checks From vs. Reply-To vs. Return-Path vs. the DKIM d= domain.
- Domain heuristics - flags excessive subdomains, lookalike-brand character substitution, and brand impersonation.
- Body & link analysis - catches display-text-vs-destination mismatches, raw-IP links, URL shorteners, punycode/IDN domains, and credential- or urgency-language.
- Attachment filename check - flags dangerous extensions and double-extension disguises (invoice.pdf.exe) from the declared filename only.
- Display-name impersonation - flags a legitimate, fully-authenticated mailbox whose display name still claims a known brand.
- OCR screenshot scanning - run a local Tesseract OCR pass on an uploaded email screenshot and apply the same heuristics - the image never leaves the device.
- Suspicion score & risk level - a transparent 0-100 score with LOW / MODERATE / HIGH / CRITICAL bands, plus a plain-language explanation for every indicator.

How It Works

MailShield runs as a small Flask web app. The interface at / accepts pasted headers or an uploaded file and posts to /analyze, which hands the input to a set of focused analyzer modules before rendering a single results page - no separate build step, no client-side framework.

- app.py - Flask routes, CSRF protection, and .txt / .json report export.
- analyzer/parser.py - raw header parsing and line-level anomaly checks.
- analyzer/authentication.py - SPF / DKIM / DMARC result extraction and alignment checks.
- analyzer/content.py - message-body and link analysis (mismatches, shorteners, urgency language).
- analyzer/risk_engine.py - the configurable Suspicion Score and risk-level weighting.

Tech Stack

Python Flask Jinja2 HTML CSS JavaScript Tesseract OCR pytesseract Pillow

Privacy & Security

Analysis runs entirely offline: no DNS lookups, no IP/domain reputation services, and no outbound network requests of any kind. The Flask dev server binds to 127.0.0.1 only. MailShield never sends email, executes attachments, or visits a link automatically - and nothing you paste or upload is stored permanently.